

(d) Mapeo de preguntas a requisitos normativos (SOC 2 – ENS – NIS2 – RGPD)

Nota: las referencias ENS/NIS2 son genéricas para facilitar el uso transversal; en una implantación real se recomienda afinar con los controles y artículos específicos aplicables a cada organismo o sector.

Nº Pregunta	Bloque	Descripción resumida	SOC 2 TSC / CC	ENS (control/medida)	NIS2 (tema principal)	RGPD / Otros
1.x	General	Tipo de organización, tamaño, alcance, rol del respondente	N/A	N/A	Clasificación entidad (esencial/imp.)	N/A
2.1-2.5	Gobernanza	Estrategia, objetivos, reporting y rol CISO	CC1.1-CC1.3	Política de seguridad, organización de la seg.	Gobernanza, responsabilidad directiva	Responsabilidad proactiva (art. 5.2)
3.1-3.4	Comunicación	Políticas, concienciación y reporting	CC2.1-CC2.3	Concienciación, formación y comunicación	Cultura de seguridad	Funciones DPD (art. 39)
4.1-4.5	Riesgos	Metodología y alcance de análisis de riesgos	CC3.1-CC3.3	Gestión de riesgos (Magerit, etc.)	Gestión de riesgos ciber	Art. 32 (riesgo y medidas)
5.1-5.5	Monitorización	SOC, MTTD/MTTR, logs	CC4.1-CC4.2	Registro de actividad, detección de incidentes	Detección y respuesta	Notificación brechas (arts. 33-34)
6.1-6.3	Controles	Inventario y automatización de controles	CC5.1-CC5.3	Controles de explotación, medidas de protección	Medidas técnicas y organizativas	Seguridad del tratamiento (art. 32)
7.1-7.4	Accesos	MFA, cuentas privilegiadas, revisiones, acceso físico	CC6.1-CC6.6	Control de acceso lógico y físico	Gestión de accesos y privilegios	Confidencialidad / minimización
8.1-8.4	Vulnerabilidades	Parches, SLA, escaneos	CC7.1-CC7.3	Protección frente a código malicioso, hardening	Medidas técnicas	Seguridad del tratamiento
9.1-9.3	Cambios	Gestión de cambios y DevSecOps	CC8.1-CC8.2	Gestión de cambios, desarrollo seguro	Resiliencia operativa	Buenas prácticas de seguridad

10.1-10.3	Mitigación	Planes de acción y lecciones aprendidas	CC9.1-CC9.2	Mejora continua, auditoría	Gestión de incidentes y aprendizaje	Responsabilidad proactiva
11.x	Disponibilidad	BCP/DRP, SLA, redundancia	A1.1-A1.3 (Disponibilidad)	Continuidad, disponibilidad, recuperación	Continuidad de servicios esenciales	N/A
12.x	Integridad	Controles de integridad de procesos	P1.1-P1.3 (Processing Integrity)	Integridad de la información	Integridad de servicios	N/A
13.x	Confidencialidad	Clasificación, cifrado	C1.1-C1.3 (Confidentiality)	Protección de la información	Confidencialidad de servicios	Art. 32 (cifrado), art. 25
14.x	Privacidad	DPIA, derechos interesados, registros de tratamientos	PI1.1-PI1.5 (Privacy)	Protección de datos personales	Datos personales y brechas	RGPD (arts. 30, 35, 12-23)
15.x	Proveedores	Evaluación de terceros, revisión de SOC 2 de proveedores	CC1-CC9 (según control)	Relación con proveedores	Cadena de suministro	Encargados del tratamiento (art. 28)
16.x	IA	Riesgos de IA y automatización	CC3, CC7-CC9	Gestión de nuevas tecnologías	Gestión de riesgos emergentes	Ética de datos y gobernanza
17.x	Percepción	Madurez, recursos, drivers de inversión	CC1-CC4	Gestión estratégica de la seguridad	Gobernanza global	N/A